

KC桌面——外资精译

全球银行

神话级时代：网络安全比信用风险更令人担忧

我们认为，银行网络安全目前是估值中未被反映的最大未定价风险之一，部分原因在于可获取的披露信息有限，导致银行之间在应对新兴网络安全风险（事件前和事件后流程）的准备程度或准备不足方面缺乏可比性，而这一风险由前沿模型等先进人工智能能力驱动。尽管监管层高度关注资本比率，但我们认为通过资本框架的视角审视网络安全风险并非最佳方法。我们认为，应更加关注由网络安全驱动的流动性风险，并通过加强基础设施韧性测试以及存款挤兑流动性折价测试来检验这一风险，因为我们相信，在社交媒体可能引发存款流动前所未有的波动（正如我们在CS事件中所见）的潜在银行危机情景中，流动性而非信用风险可能是主要触发因素。在这种变化的环境中，我们可能会看到不同参与者之间的分化，基于：i.) 地缘政治——美国参与者可能具有优势，能够早期获取最先进的人工智能模型，美国是人工智能发展的中心（例如，玻璃翼项目），其次是中国，其似乎也领先于同行，而世界其他地区可能处于劣势；ii.) 规模和互联性，因为全球系统重要性银行相比小型银行可能更早获得测试最新发展的机会。我们也开始质疑，与其纯粹关注盈利，我们是否应该基于对“粘性”客户存款银行（拥有大量超额存款）应对下一次危机情景能力的看法，给予其1倍更高的估值倍数（即更低隐含股权成本）。我们认为，美国全球系统重要性银行（目前彭博一致预期2028年预期市盈率平均12.5倍）相比全球同行（欧洲银行2028年预期市盈率9倍，日本大型银行2028年预期市盈率12倍）享有一定溢价是合理的，因为市场通过更高的绝对可扩展技术支出和早期获取最新前沿模型，将更好的网络风险准备纳入考量，从而降低了股权成本。

诸如Mythos和GPT-5.5等前沿模型将发现此前未知的“零日”漏洞的时间线从数月 and 数年大幅缩短至数小时。虽然这些模型凸显了所有全球银行面临的网络风险敞口，但自下而上看，我们认为风险敞口更大的银行是那些拥有老旧且多个遗留基础设施拼凑而成、且持续投资不足的银行：i.) 拥有遗留核心银行系统的银行，这些系统运行在几十年前编写的代码上，但由于缺乏资源或缺乏基础设施协议，未能展现出修复已识别漏洞所需的敏捷性；ii.) 核心银行系统由供应商提供，且供应商未能展现出为已识别漏洞发布补丁所需敏捷性的银行；iii.) 拥有多个遗留平台（例如由于历史并购）的银行，从而提供了更大的潜在脆弱点池；以及iv.) 无法获取该领域最新发展的银行，使其可能比能够获取这些发展的同行更长时间地暴露于“已知威胁”之下。作为外部观察者，我们很难在此基础上区分不同银行，因为：i) 我们没有足够的信息了解各家银行的信息技术主系统、后台基础设施、中台和外部供应商依赖情况，因此我们将信息技术支出视为银行

JPM证券

专业销售联系方式：

Gigi Sparling - 专业销售 - 欧洲金融业

至少拥有资源以保持领先并随时修复这些漏洞的晴雨表。基于表1，2025年技术成本平均约占全球银行运营费用的17%，尽管不同参与者对技术支出的定义各不相同，使得同类比较困难，但这为与银行管理层进行讨论提供了一个起点。由于技术具有可扩展性，我们也关注绝对支出，美国大型银行在技术上的绝对支出高于全球同行，处于有利地位，而欧洲银行通常技术绝对预算较低，并且在获取某些最新发展方面面临延迟，例如，它们缺席了Anthropic在4月关于玻璃翼项目的公告。

总体而言，我们认为技术支出以及网络安全应成为银行投资者和管理层更重要的讨论话题，重点在于自下而上地了解银行所拥有的基础设施。JPM董事长兼首席执行官杰米·戴蒙在其2025年致股东信中强调，网络风险仍是摆在我们面前、多年未决且尚未解决的最大风险之一，“网络风险。我必须提及这一点，因为它仍然是我们最大的风险之一，这对许多其他主要行业和公司可能也是如此。人工智能几乎肯定会加剧这一风险。我们投入巨资保护自己并保持警惕。”我们目前对欧洲银行2025-2028年期间年均成本增长1.8%的预测，可能因技术投资

需求增加而面临上行压力；然而，我们也预计随着时间的推移，人工智能使用的增加将带来成本节约，从而在一定程度上抵消影响。我们还认为，随着金融犯罪日益复杂化，需要加快立法步伐来处理网络安全问题——不是通过银行监管资本或流动性要求，而是通过对网络攻击事件中的基础设施和流程进行回溯。

我们此前讨论过数字货币使用增加和去中心化金融市场发展作为全球银行下一个前沿领域的影响（参见《全球银行：下一个前沿：数字货币将定义全球银行业的未来》），网络安全领域的发展预计也将影响去中心化金融市场。金融服务中代理型人工智能使用的增加也带来了新的风险，并进一步扩大了攻击面。虽然使用冷钱包的可能性提供了有限程度的保护，但在量子计算快速发展的时代，去中心化金融市场仍然容易受到网络攻击。然而，以太坊基金会表示，虽然量子计算机最终将威胁到以太坊今天使用的密码学，但它拥有专门的量子后研究团队，以及一个结构化的“精简以太坊”路线图，目标是在2029年实现全面的量子后保护。诸如用于账户签名的EIP-8141标准、抗量子应用层零知识证明以及精简共识路线图，是以太坊基金会认为易受量子攻击的一些领域中的部分发展成果。

具有讽刺意味的是，尽管数字优先身份验证是趋势，但随着网络攻击日益复杂，尤其是那些由人工智能加设备入侵助力的攻击，银行有可能重新强调物理持有因素（硬件令牌/安全密钥），因为它们通常更能抵御远程盗窃、网络钓鱼和某些形式的欺骗。然而，如果这种情况真的发生，银行需要在客户便利性（因需要携带物理设备而受到影响）与这一举措所提供的安全性之间取得平衡。我们也可能会看到断路器被越来越多地部署的场景，例如，用于限制网络安全事件的连锁反应损害。例如，我们看到新加坡的银行对特定的数字银行交易设置了冷静期，目的是为受影响的用户提供一个窗口，以检测和报告与其账户相关的任何可疑活动，例如添加新的转账收款人。我们还看到，银行面向外部部署Agentic AI的速度正在放缓，因为具有第三方连接的Agentic生态系统所提供的不断扩大的攻击面，可能导致对前沿模型持谨慎态度，从而凸显其脆弱性。

Anthropic的Claude Mythos预览版（Mythos，于2026年4月发布）在多个授权机构（如英国AI安全研究所）的控制评估下，已被报道展现出比任何其他模型都显著更先进的AI网络能力。这些评估表明，Mythos能够自主发现并利用暴露网络上的漏洞，执行多阶段攻击，这些工作通常需要人类专业人员数天才能完成。Mythos只是未来AI能力的一个例子，其他模型如GPT-5.5在机构的网络评估中也展现出相似水平的性能（见图1），我们预计随着时间的推移，将开发出更复杂的模型，这意味着银行和监管机构需要动态地应对不断演变的网络安全格局。虽然像Glasswing这样的项目也展示了企业与当局合作利用这些模型加强网络防御的力量，并且这些模型的普遍可用性受到限制，但我们认为漏洞被发现的速度正在加快，从漏洞识别到修补之间的反应时间正在压缩，这将继续构成挑战。

随着网络安全相关事件的增加，我们认为网络保险对银行将变得越来越重要，以避免出现捷豹路虎（JLR）那样的情况——根据新闻报道（来源：英国《金融时报》），该公司因缺乏网络保险，不得不独自承担2025年一次破坏性网络攻击的全部损失。慕尼黑再保险估计，2025年全球网络保险市场保费总额接近150亿美元，慕尼黑再保险专家预计，到2030年全球保费规模将扩大至约280亿美元，这意味着2020年至2030年间全球年均增长率为15%。我们注意到，金融服务业是全球网络保费的最大支付方之一，在网络风险增加的时代，我们预计监管机构将越来越关注银行所获得的网络保险保障。我们认为，监管机构还应考虑将网络风险保险纳入银行的运营资本框架，以激励银行通过网络保险购买适当的保障。

我们认为，人工智能主导的网络威胁的进步意味着，由于代码中的漏洞更容易被利用，很难使系统100%安全。然而，网络威胁已经“制度化”，网络攻击者使用投资回报率（ROI）等指标来衡量潜在回报与执行攻击所需投资之间的关系。那些通过进行必要的前期投资来提高这一ROI门槛的银行，将比同行处于更有利的地位。与此同时，人工智能主导的发展可能会降低不良行为者实施复杂网络攻击的成本，因此，观察通过修补漏洞实现的人工智能增强曲线与实施人工智能主导攻击的便利性曲线未来将在何处交汇，将是一件有趣的事情。

前沿模型网络性能的提升增加了银行的网络安全风险……

前沿模型是特定时刻可用的最先进的AI模型，它们在庞大的数据集上进行训练，以在许多任务中提供最先进的性能，代表了AI能力的前沿。它们通常为高级推理、图像和文本生成以及Agentic工作流提供动力。（来源：英伟达）Mythos预览版和GPT-5.5都是前沿模型的例子。

Anthropic于2026年4月披露的Claude Mythos预览版就是这样一种前沿模型，据该公司称，它揭示了这样一个事实：“AI模型的编码能力已达到一个水平，在发现和利用软件漏洞方面，它们可以超越除最熟练人类之外的所有人。” Anthropic还宣布了Project Glasswing，据称这是一项新举措，汇集了亚马逊云服务、Anthropic、苹果、博通、思科、CrowdStrike、谷歌、JPM、Linux基金会、微软、英伟达和Palo Alto Networks，旨在保护世界上最重要的软件。

Mythos比以前的工具先进在哪里？简单来说：1. Mythos发现并随后利用漏洞的速度比以前的工具快得多；2. 微小的漏洞可以被组合成严重的攻击。同样，Mythos的攻击速度比以前的工具快得多；3. Mythos可以对闭源软件进行漏洞利用的逆向工程，并将已知但尚未广泛修补的漏洞转化为可利用的漏洞。

英国AI安全研究所（AISI）对Anthropic的Claude Mythos预览版（于4月7日宣布）进行了评估，以评估其网络安全能力，并确认其能力显著提升，该系统能够自主发现和利用漏洞，端到端地执行多阶段攻击链，并在专家级黑客任务上达到了73%的成功率，而在此之前，没有模型能在2025年4月之前完成这些任务。该研究所对GPT-5.5早期检查点的评估结果表明，GPT-5.5模型在AISI的网络评估中也达到了相似水平的性能，这表明网络性能的这一跃升是一个更广泛的趋势，而非仅限于单一模型。

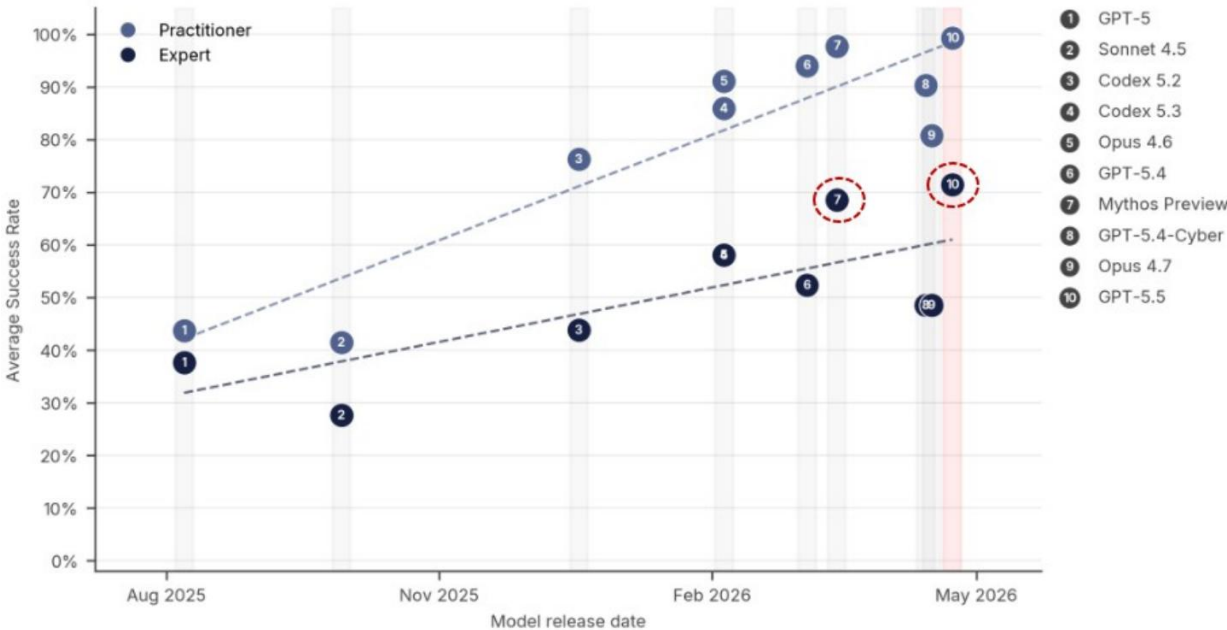
网络性能的提升，尽管是在受控环境下进行的，没有考虑现实世界环境中潜在的防御机制/安全协议，但这凸显了金融机构需要改进其网络安全防御体系。

3/5

这一威胁正变得日益真实。2026年5月，谷歌首次指出，其威胁情报组（GTIG）识别出一个威胁行为者使用了其认为由人工智能开发的零日漏洞。该犯罪威胁行为者计划将其用于大规模攻击事件，但主动的反向发现可能阻止了其使用。

2026年2月，AISI内部估算，自2024年底以来，AI模型能完成的网络任务时长每4.7个月翻一番——这已较其2025年11月估算的8个月有所加速。此后，AISI报告了两个新模型——Claude Mythos Preview和GPT-5.5，它们均大幅超出了上述两种翻倍趋势。AISI在5月表示，尚不清楚这是否代表一种新的、更快的趋势。

图1：Mythos与GPT-5.5在前沿模型基础上的网络性能跃升
在5000万token预算下，高级网络任务的平均成功率。27项实践者任务，21项专家任务
按模型划分的高级CTF表现（5000万token预算）



图表 1

在CTF（夺旗）挑战中，AI模型必须识别并利用目标系统中的弱点，以检索隐藏的“旗帜”。来源：英国AI安全研究所（见此处）

Anthropic还指出，其披露的漏洞数量只是Mythos Preview发现漏洞总数的一个子集，因为独立的人工分类和审查流程是限制速度的环节。

图2：Anthropic开源漏洞仪表板，显示所有严重程度漏洞（而非仅Mythos Preview估计为高或严重程度漏洞）。



图表 2

……银行基础设施的不同层级受到AI主导网络攻击威胁的影响

传统核心银行系统最容易受到AI主导网络攻击这一新兴威胁的影响，因为全球银行的部分银行平台仍运行在数十年前用COBOL等语言编写的代码上，而当前一代程序员可能不熟悉原始程序员编写这些代码的逻辑和理解。Mythos等前沿模型能够理解这些代码行，从而能够突出显示潜在漏洞，这些漏洞此前可能因缺乏全面理解而无法检测。

开源漏洞对银行的客户面向平台可能尤为关键，而银行广泛使用此类开源库意味着，如果被恶意行为者利用，一个漏洞可能产生重大后果。Anthropic指出，Mythos Preview检测到的一个开源漏洞示例存在于wolfSSL中，这是一个以安全性著称的开源加密库，被全球数十亿设备使用。Mythos Preview构建了一个漏洞利用程序，可让攻击者伪造证书，从而（例如）允许他们为银行或电子邮件提供商托管虚假网站。该网站对最终用户来说看起来完全合法，尽管由攻击者控制。wolfSSL表示，超过50亿个应用程序和设备受到wolfSSL产品的保护，我们认为这凸显了漏洞利用可能造成的潜在破坏范围。在2026年5月的一份发布中，Anthropic表示，它已使用Mythos Preview扫描了超过1000个开源项目，这些项目共同支撑了互联网的大部分基础，并且Mythos Preview在这些项目中发现了其估计的6202个高或严重程度漏洞（总共23019个，包括其估计为中或低严重程度漏洞）。

银行经常使用来自第三方的供应商固件，而固件中无法远程修补的延迟或过长的补丁周期将使银行面临网络安全风险。七国集团指出，AI软件供应链安全正变得越来越重要，多项国际倡议正在进行中。作为这项工作的一部分，该集团发布了面向公共和私营部门利益相关者的可操作指南，说明在AI软件物料清单（SBOM）中合理期望的内容，以提高AI供应链的透明度和网络安全。它由一份结构化记录或清单组成，包含构建AI系统所用各种组件的详细信息和供应链关系。

对云服务商的集中依赖是另一个潜在漏洞，FCA指出，如果多家金融机构都依赖同一个AI平台（集中度风险），而该平台存在漏洞，那么一次AI增强攻击可能同时打击多个目标，从而可能威胁金融稳定。如果没有新方法，传统的网络防御和调查方法可能会被自我演进的AI威胁超越。

美国大型银行定位更佳，美国是AI最新发展的中心，其次是中国

我们看到，随着美国占据领先地位，地缘政治变化在AI主导权中发挥作用，美国是主要AI发展/突破的中心，其次是中国，后者似乎也在AI方面推进了自身模型和战略。欧洲目前似乎处于劣势，这也反映在美国政府近期对某些Anthropic模型的禁令中，该禁令援引国家安全权力，发布了一项出口管制指令，暂停任何外国国民（无论在美国境内还是境外，包括外国籍的Anthropic员工）对Fable 5和Mythos 5的所有访问。Anthropic表示，该指令的净效应是，它必须禁用Fable 5和Mythos 5以确保合规。所有其他Anthropic模型的访问不受影响。（来源：Anthropic）随后，我们注意到媒体报道（来源：彭博）称，Anthropic在6月27日的一份声明中指出部分限制已解除：“我们收到美国政府的的通知，我们最强的网络安全模型Mythos 5可以重新部署给一小部分网络防御者和基础设施提供商，”Anthropic在一份声明中表示。“我们正在努力配置获批的提供商，并尽快恢复他们对Mythos 5的访问。我们很高兴看到这一进展，并将继续与政府合作，扩大对Mythos 5的访问，并让Fable 5再次可供普遍使用。”

在美国，我们注意到对量子创新的关注度提升，这反映在近期（6月22日）关于美国量子技术创新及加强该领域国家安全的行政令中。该行政令指示相关机构与部门评估商用量子计算机规模与性能提升所带来的国家安全影响，例如向量子密码学迁移的影响。在欧洲，欧盟委员会于2025年7月通过了一项量子战略，旨在到2030年使欧洲成为全球量子领导者。当时，欧盟承认尽管在量子技术方面取得了显著进展，但在将创新能力和未来潜力转化为实际市场机会方面仍落后，同时各成员国的战略与路线图存在碎片化问题。在英国，《国家量子战略》于2023年3月发布，提出了到2033年成为领先量子驱动型经济的十年愿景，以及英国量子技术发展计划。

总体而言，在量子计算最新模型与发展的早期获取场景下，美国银行在网络安全方面相比全球同行可能具备优势。此外，我们认为，科技支出更高的美国银行也更有能力投资并跟上AI/网络安全的最新发展。

我们注意到日本的最新动态。据媒体报道，引用日本财务大臣葛饰幸子（来源：共同社）的说法，日本三大巨型银行据称已获得谷歌有限责任公司的新型人工智能模型，该模型在检测计算机系统漏洞方面能力很强。我们认为，这反映出全球各国政府日益重视来自金融网络犯罪中更复杂行为体的威胁。

表1：部分全球银行的IT支出——美国IT支出最高，但全球银行正在追赶 区域平均值为所选银行的平均值。

来源：JPM估算，公司数据。注：IT费用的定义在各公司间可能不可比。对于谷歌/Alphabet AR25——研发成本，亚马逊AR25——技术与基础设施费用。对于CASA，IT成本为JPM基于2024年上半年IT投资份额的估算。对于PM，IT支出基于2026年2月公司更新中披露的增长。对于BNPP，我们假设IT成本占总成本的20%。对于UBS和MS，技术成本估计约为收入的10%。对于DB和荷兰银行，IT成本来自各自AR25。JPM估算GS、德国商业银行、BAWAG、荷兰国际集团、法国兴业银行、意大利联合信贷银行。对于纽约梅隆银行，技术投资在公司电话会议中披露。对于桑坦DB行，IT+通信成本在AR25中。对于BAWAG，运营费用根据AR25合并利润表。HSBC：基于2023年披露。BARC：基于2023年英国技术/运营成本披露。劳埃德：JPM估算基于3年30亿英镑，主要用于技术/数据，占其他费用的50%（比例与历史一致）。NatWest：JPM估算基于2023-25年35亿英镑投资，80%用于技术/数据+20%的行政成本。澳大利亚银行的报告期可能与其他银行不一致。日本银行和Citi基于2024年数据。

表2：部分全球银行关于Mythos的评论摘录

来源：彭博财经有限合伙公司

监管机构已加大力度应对日益加剧的威胁

全球各地的监管机构和政府已加大力度应对前沿模型带来的日益加剧的网络安全风险。欧洲央行的《数字运营韧性法案》于2025年生效，确保银行、保险公司、投资公司及其他金融实体能够承受、应对信息通信技术中断（如网络攻击或系统故障）并从中恢复。DORA为金融行业的运营韧性带来了规则协调，适用于20种不同类型的金融实体和信息通信技术第三方服务提供商。

DORA还旨在加强对关键第三方提供商（如云服务提供商）的监督。此外，DORA赋予监管机构测试（威胁主导渗透测试）金融机构是否能够检测、应对复杂攻击（模拟真实世界威胁）并从中恢复的任务，从而为韧性提供更具系统性和可执行性的框架。（来源：欧洲央行执行委员会成员兼欧洲央行监事会副主席Frank Elderson的演讲，2026年6月）

2024年，欧洲央行对109家银行进行了网络韧性压力测试，其中28家银行接受了更全面的评估，以检验其应对严重但合理的网络安全事件并从中恢复的能力。该测试主要为定性测试。测试中获得的见解将用于更广泛的2024年监管审查与评估流程。测试结束后，银行收到了一份针对其改进建议的专项报告，联合监管团队将在其常规监管活动中跟进。由于这不是一项关注银行资本的压力测试，其结果不会影响银行的第二支柱指引。

欧洲央行监事会副主席兼执行委员会成员Frank Elderson在5月的一次采访中，承认欧洲银行无法获取Mythos，同时强调银行需要加倍努力，利用现有AI工具识别漏洞，即使是微小漏洞。他们的补丁修复方法也需要改变。那些曾被认为微小（因此通常只在较长周期内修补）的漏洞，必须被视为紧急事项并立即修复。

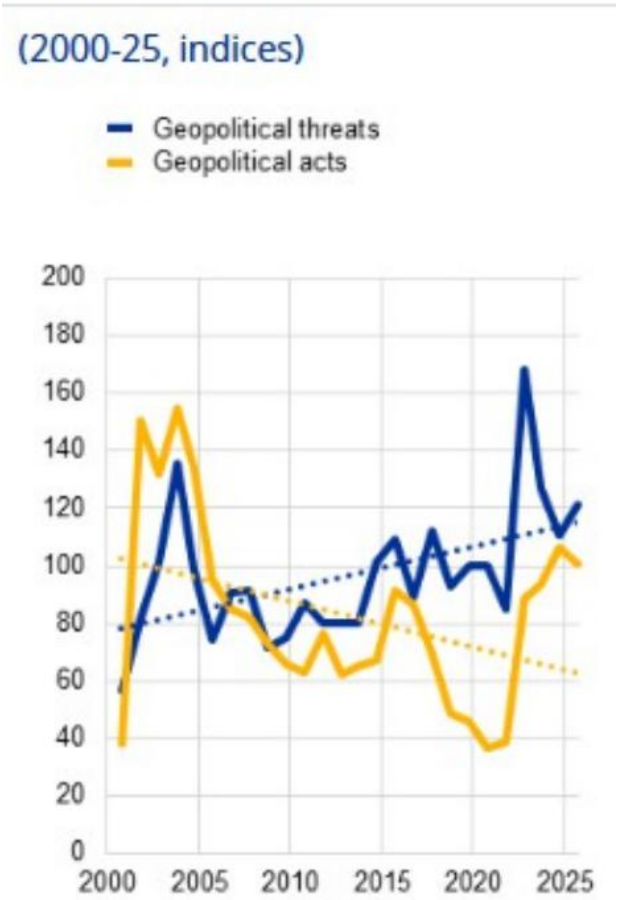
在美国，总统于2026年6月签署了一项行政令，包括与AI行业和关键基础设施运营商自愿合作，成立一个AI网络安全信息共享中心，负责协调和化解软件漏洞扫描冲突，发现并验证此类漏洞，以及协调和优先处理漏洞补丁的修复与分发。该行政令还涉及安全部署前沿模型的主题，要求AI开发者在计划向其他可信合作伙伴发布“涵盖的前沿模型”之前，最多提前30天向联邦政府提供访问权限。

在英国，英国央行表示，除了全球合作外，它继续与AI安全研究所密切合作，以更好地理解涉及前沿AI代理的潜在金融稳定风险，并与数字监管合作论坛合作。

在当前复杂的地缘政治格局下，来自国家及国家支持行为体的网络攻击威胁，使得银行及其他机构更有必要提高警惕，因为这些攻击可能变得更加复杂。

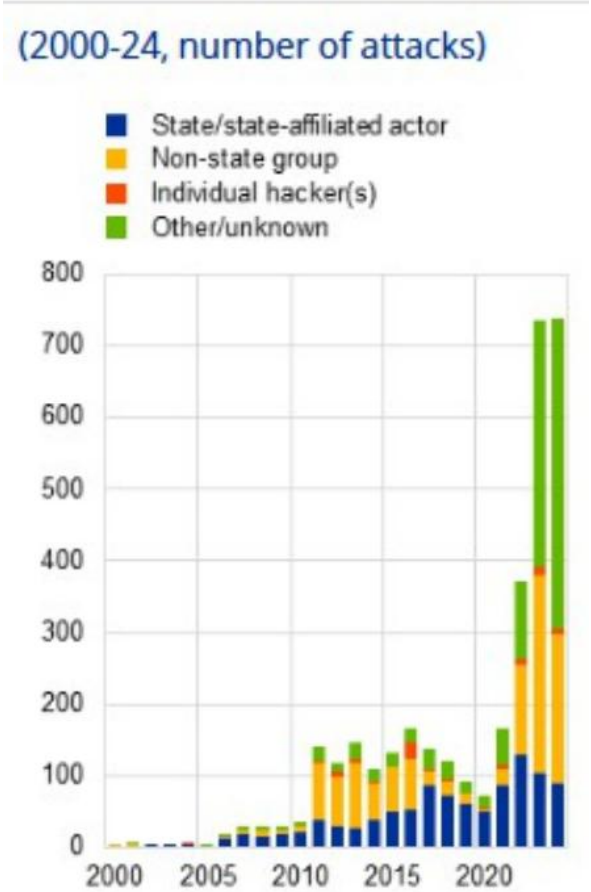
作为其2025年5月《金融稳定评估》（见此处）的一部分，欧洲央行指出，网络攻击在混合冲突的实施中正扮演着越来越重要的角色。欧洲央行表示，尽管网络攻击（包括成功与不成功的）的确切数量仍未知，但公开披露的数据显示，过去十年间此类攻击的数量大幅增加，某些年份出现了大量由国家支持的攻击。此外，一些国家不仅通过专门的军事或情报单位开展网络活动，还通过代表其行事的网络犯罪团伙进行。

图3：地缘政治紧张局势日益伴随着国家支持的网络攻击 a) 地缘政治威胁与地缘政治行为指数



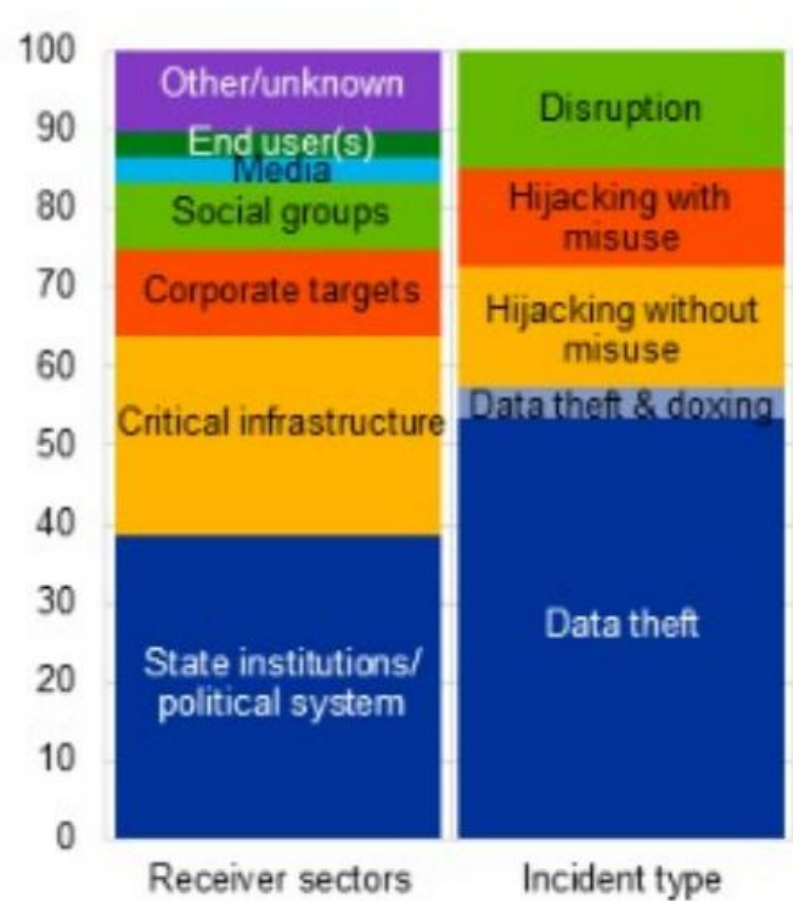
图表 3

b) 按威胁行为者类型划分的网络攻击随时间变化情况



图表 4

c) 按目标行业和事件类型划分的国家支持的网络攻击



图表 5

注：图a：该图显示了月度地缘政治威胁与行为指数的年度平均值。2025年的平均值涵盖1月至4月。图b和图c：“国家/国家关联行为者”指由国家行为体或暗示有国家关联的非国家行为体实施的攻击。这些攻击与图c中标注为“国家支持的网络攻击”相同。图b显示了截至2024年的年度网络攻击数量，而图c仅显示了国家支持的网络攻击子集，但覆盖了EuRepoC数据库自2000年1月至2025年2月25日的完整样本期。

来源：欧洲央行《金融稳定评估》，2025年5月